ACLs are typically evaluated at authorization time, just before a resource is accessed—whether that means opening a file, retrieving a database record, or executing a command. The system performs a synchronous, binary check: does the ACL for this resource allow this principal to perform this action?

What unifies all ACL-based systems is their resource-centric logic. Each decision depends solely on the identity of the requestor and the list of permissions attached to the resource, not on external attributes or policies. This makes ACLs fast and easy to reason about locally, but increasingly difficult to manage at scale.

5.1.2 Mapping ACLs onto the authorization reference architecture

Even though ACLs are one of the oldest authorization models, they still map cleanly onto the components of the reference architecture introduced in chapter 4. Because ACLs are often embedded directly in the resource or application, the architecture is usually tightly coupled, but the roles of enforcement, decision-making, and data sourcing are still present. Table 5.1 shows how each of the four core components—PEP, PDP, PAP, and PIP—is typically realized in an ACL-based system.

Table 5.1 Mapping ACLs onto the authorization reference architecture. Each component has a place in ACL-based systems, even if they're not always separated in practice.

Component	What it does	How ACLs implement it
Policy Enforcement Point (PEP)	Intercepts access requests and enforces the decision	Typically, the application or resource itself (for example, file system, database, service)
Policy Decision Point (PDP)	Determines whether the requested action is allowed	Usually, embedded logic that checks the ACL attached to the resource
Policy Administration Point (PAP)	Manages and stores roles, permissions, and assignments	Often local to each resource (for example, filesystem metadata, in-resource access list, or admin interface)
Policy Information Point (PIP)	Supplies user and role data to the PDP at runtime	Commonly derived from the identity context passed to the system (for example, OS user ID, authenticated principal)